

SYSCLIN

MANUAL DE SEGURIDAD

Políticas, controles y validaciones del sistema

Sistema SYSCLIN de gestión clínica

Versión 1.0

22/10/2026

Documento confidencial

CONTROL DEL DOCUMENTO

Campo	Valor
Documento	Manual de seguridad
Sistema	Sysclin, gestión clínica (agendamiento, consultorio, ventas)
Destinatario	Todo el personal, administrador y soporte técnico (ver «Cómo está organizado»)
Versión	1.0
Fecha de generación	22/10/2026
Revisión	Cada 6 meses, o después de un incidente o un cambio de infraestructura
Confidencialidad	Las Partes B a D describen controles de administración y no se entregan a los usuarios finales
Referencias	ISO/IEC 27002:2013; NIST SP 800-61 rev. 2 (respuesta a incidentes)

	Nombre	Firma	Fecha
Elaborado por			
Revisado por			
Aprobado por			

HISTORIAL DE REVISIONES

Versión	Fecha	Descripción del cambio
1.0	22/10/2026	Emisión inicial

ÍNDICE

1. Introducción....8
1.1 Cómo está organizado....8
1.2 Lo que el sistema hace por usted....8
2. Cómo ingresar de forma segura....10
2.1 Los pasos para entrar....10
2.2 ¿Por qué me pide un código?....11
2.3 Reglas que conviene conocer....11
3. Su contraseña....13
3.1 Qué debe tener....13
3.2 Cómo crear una fácil de recordar....13
3.3 Cuidados....13
3.4 Si olvidó su contraseña o necesita cambiarla....14
4. Qué puede ver cada persona....15
5. Su sesión y su computadora....16
6. Cómo cuidar la información....17
6.1 Un usuario por persona....17
6.2 Datos que no se deben cargar....17
6.3 Informes y documentos....17
6.4 Correos falsos....17
6.5 Todo queda registrado....18
7. Validación de los datos que se cargan....19
7.1 Cómo se controla: tres capas....19
7.2 Tipos de aviso....19
7.3 Dónde ver el detalle....20
8. Si algo no está bien....21
9. Copias de respaldo....22
9.1 Cómo funciona....22
9.2 Lo que depende de usted....22
10. Calendario de tareas....23
11. Qué hacer ante un incidente....24

12. Validaciones de Personas....25
12.1 Funcionarios....25
12.2 Pacientes....25
12.3 Usuarios....26
13. Validaciones de Agendamiento....27
13.1 Agenda Medica....27
13.2 Citas....28
13.3 Lista de Espera....30
14. Validaciones de Clínico....31
14.1 Consultas....31
14.2 PEI....33
14.3 Fichas Medicas....33
15. Validaciones de Ventas....34
15.1 Pedidos....34
15.2 Presupuestos....34
15.3 Estado de Caja....35
15.4 Historial de Caja....35
15.5 Arqueos de Caja....36
15.6 Facturas....36
15.7 Remisiones....37
15.8 Notas de Credito....38
15.9 Notas de Debito....38
15.10....Cobranzas 39
15.11....Recaudaciones 40
16. Validaciones de Configuración....41
16.1 Cajas....41
16.2 Cargos....41
16.3 Condiciones de Venta....41
16.4 Consultorios....42
16.5 Depósitos....42

16.6 Diagnósticos....42
16.7 Empresa....43
16.8 Entidades Adheridas....43
16.9 Entidades Emisoras....43
16.10....Especialidades 44
16.11....Estados de Factura 44
16.12....Formas de Cobro 44
16.13....Instrumentos 45
16.14....Insumos 45
16.15....Ítems / Servicios 45
16.16....Marcas de Tarjeta 46
16.17....Medicamentos 46
16.18....Monedas 46
16.19....Sedes 46
16.20....Signos 47
16.21....Síntomas 47
16.22....Tipos de Análisis 48
16.23....Tipos de Certificado Médico 48

16.24 Tipos de Comprobante 48
16.25 Tipos de Estudio 48
16.26 Tipos de Impuesto 49
16.27 Tipos de Ítem 49
16.28 Tipos de Procedimiento 49
16.29 Tipos de Tratamiento 50
16.30 Timbrados 50
16.31 Puntos de Expedicion 51
16.32 Roles y Permisos 51
16.33 Auditoria 51
16.34 Menu 51
17. Objetivo, alcance y clasificación de la información 53
17.1 Objetivo 53
17.2 Alcance 53
17.3 Convenciones de este manual 53
17.4 Clasificación de la información 53
18. Contraseñas y autenticación 55
18.1 Usuarios del sistema 55
18.2 Credenciales de servicio 56
18.3 Por qué no se guarda historial de contraseñas 56
19. Roles y control de acceso 57

19.1 Roles de la aplicación....57
19.2 Roles de la base de datos....57
20. Seguridad de la aplicación....58
20.1 SECRET_KEY....58
20.2 Cookie de sesión....58
20.3 Modo depuración....58
20.4 IP de los usuarios en auditoría....58
20.5 Bloqueo de cuentas y límites de intentos....59
21. Auditoría y chequeo periódico....61
21.1 Qué se registra....61
21.2 Cambios en datos....61
21.3 Alertas e informe semanal....61
21.4 Chequeo de seguridad periódico....62
22. Respuesta a incidentes....64
22.1 Casos frecuentes....64
23. Riesgos aceptados y normativa....66
23.1 Riesgos aceptados....66
23.2 Pendiente de incorporar....66
23.3 Normativa de referencia....66
Anexo A. Preguntas frecuentes....67
Anexo B. Glosario....68
Anexo C. Contactos....69

ÍNDICE DE FIGURAS

Figura 2.1. Pantalla para escribir el código de verificación....10
Figura 2.2. Correo con el código de verificación....11

1. Introducción

El sistema guarda **historias clínicas, datos personales de los pacientes y la facturación**. Es información sensible: si llega a manos equivocadas puede perjudicar a los pacientes y a la clínica. Por eso Sysclin tiene protecciones que funcionan solas y algunas reglas que dependen de cada persona que lo usa.

Este manual explica, sin términos técnicos, **qué hace el sistema para proteger los datos** y **qué debe hacer usted** para que esas protecciones funcionen. El uso de las pantallas lo explica el Manual de usuario, y la operación del servidor, el Manual de infraestructura.

1.1 Cómo está organizado

Capítulos	Para quién	Qué contienen
Cómo ingresar de forma segura, Su contraseña, Qué puede ver cada persona, Su sesión y su computadora, Cómo cuidar la información, Validación de los datos y Si algo no está bien	Todo el personal	Lo que debe hacer cada persona para que las protecciones funcionen
Copias de respaldo, Calendario de tareas y Qué hacer ante un incidente	Administrador	Tareas de seguridad de quien administra el sistema
Validaciones de cada módulo	Administrador y soporte técnico	Los avisos que muestra el sistema en cada pantalla
Objetivo y alcance, Contraseñas y autenticación, Roles, Seguridad de la aplicación, Auditoría, Respuesta a incidentes y Riesgos aceptados	Soporte técnico	Políticas y controles técnicos

Nota: Los recuadros **Nota** señalan reglas que hay que cumplir siempre; los recuadros **Advertencia**, acciones que pueden causar pérdida de datos o un problema de seguridad.

1.2 Lo que el sistema hace por usted

Estas protecciones están siempre activas; no tiene que hacer nada para que funcionen:

Protección	Qué significa en la práctica
Contraseñas protegidas	Las contraseñas se guardan cifradas. **Nadie puede verlas**, ni siquiera el administrador o el soporte técnico
Código por correo	Además de la contraseña, el sistema envía a su correo un código para entrar. Aunque

Protección	Qué significa en la práctica
	alguien conozca su contraseña, sin su correo no puede ingresar
Bloqueo automático	Si alguien intenta adivinar su contraseña, la cuenta se bloquea 30 minutos después de 5 intentos; si sigue fallando, 1 hora; y después solo un administrador puede desbloquearla. Le llega un correo de aviso
Freno por equipo	Si desde un mismo equipo se fallan 10 ingresos en 15 minutos, el sistema frena los intentos desde ese equipo
Acceso por rol	Cada persona ve solo lo que necesita para su trabajo
Cierre automático	Si el sistema queda 20 minutos sin uso, cierra la sesión solo
Registro de actividad	El sistema anota quién ingresó y quién creó, modificó o anuló cada dato, con fecha y hora. Ese registro no se puede modificar ni borrar
Nada se borra	Los usuarios se desactivan y los documentos importantes se anulan indicando el motivo, así siempre queda el historial. La historia clínica se conserva
Copias de respaldo	Cada 24 horas se guarda una copia cifrada de toda la información, y se conservan las de los últimos 14 días
Alertas al administrador	El sistema avisa por correo de las anulaciones y de los cambios hechos fuera del horario de atención, y envía un informe semanal los lunes

2. Cómo ingresar de forma segura

2.1 Los pasos para entrar

1. Abra el navegador e ingrese a la dirección del sistema que le dio el administrador.
2. Escriba su **usuario** y su **contraseña** y presione **Ingresar**.
3. Revise su correo: llega un **código de 6 números**. Escríbalo en la pantalla y presione **Verificar**. El código vale **5 minutos**.



Figura 2.1. *Pantalla para escribir el código de verificación*

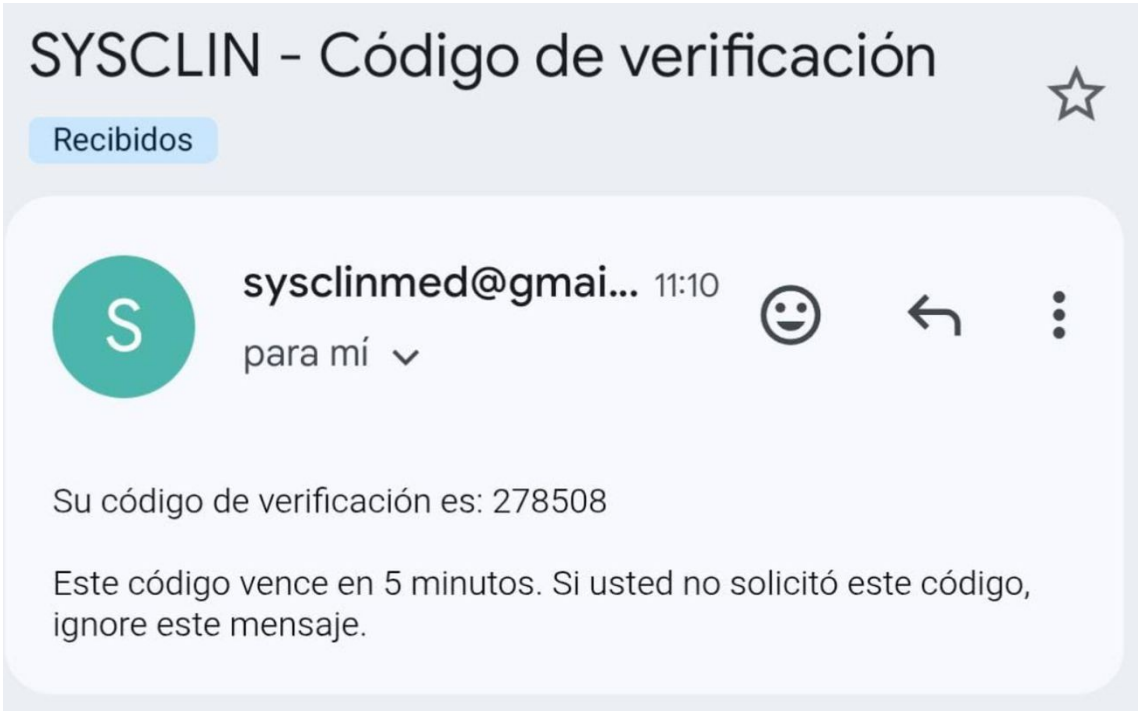


Figura 2.2. *Correo con el código de verificación*

La casilla **Recordarme en este equipo (30 días)** hace que el navegador recuerde solo su **nombre de usuario**; nunca guarda la contraseña. No la marque en una computadora compartida.

Cuando el código es correcto, el sistema recuerda ese equipo como **confiable** durante 60 días: en ese equipo no se lo vuelve a pedir. Por eso conviene ingresar solo desde su computadora de trabajo y nunca desde una compartida. Si ingresó desde un equipo ajeno, avise al administrador: puede revocar los equipos confiables de su cuenta.

2.2 ¿Por qué me pide un código?

Es una segunda llave. La contraseña es algo que usted **sabe**; el correo es algo que usted **tiene**. Para entrar hacen falta las dos, así que una contraseña robada, por sí sola, no alcanza. A esto se le llama **verificación en dos pasos**.

2.3 Reglas que conviene conocer

Situación	Qué pasa
Escribe mal el código	Tiene hasta 5 intentos con cada código. Después debe volver a ingresar para recibir uno nuevo
Pasan más de 5 minutos	El código vence. Vuelva a ingresar con su usuario y contraseña para recibir otro
Escribe mal la contraseña varias veces	La cuenta se bloquea 30 minutos después de 5 intentos; si sigue fallando, 1 hora; y después solo un administrador puede desbloquearla. El mensaje en pantalla indica hasta qué hora

Situación	Qué pasa
	dura el bloqueo y le llega un correo de aviso
No llega el código	Espere un minuto y revise la carpeta de correo no deseado. Si no llega, vuelva a ingresar para pedir uno nuevo; si sigue sin llegar, avise al administrador

Nota: Si le llega un correo de **cuenta bloqueada** o un **código que usted no pidió**, alguien está intentando entrar con su usuario. Avise al administrador ese mismo día y cambie su contraseña.

3. Su contraseña

3.1 Qué debe tener

- Entre **8 y 16 caracteres**.
- Al menos una letra **mayúscula** y una **minúscula**.
- Al menos un **número**.
- Al menos un **símbolo** de este grupo: **! @ # $ % ^ & ***
- No puede ser igual a su nombre de usuario ni contener su nombre o su apellido.
- No puede ser una contraseña muy común, como las que aparecen en las listas de contraseñas más usadas.

La contraseña **vence cada 90 días**. Cuando venza, el sistema se lo avisa al ingresar y le pide elegir una nueva.

3.2 Cómo crear una fácil de recordar

Entre 8 y 16 caracteres alcanza con una frase corta. Piense en algo que solo usted sepa, junte las palabras y agregue un número y un símbolo:

Frase pensada	Contraseña resultante	¿Sirve?
Mi perro Toby	MiPerroToby#2026	Sí: tiene 16 caracteres, mayúsculas, minúsculas, número y símbolo
Consultorio	Consultorio123	No: no tiene símbolo y es fácil de adivinar
Su nombre y su fecha de nacimiento	Ana15031990!	No: contiene su nombre (el sistema la rechaza) y cualquiera que la conozca puede adivinarla

Nota: No use los ejemplos de este manual como contraseña. Cree la suya.

3.3 Cuidados

- **Nunca la comparta**, ni con compañeros ni con el administrador. Nadie de la clínica ni del soporte técnico se la va a pedir.
- No la anote en papeles pegados al monitor o al escritorio.
- No use la misma contraseña que en su correo, redes sociales o banco.
- Si usa una computadora compartida, no acepte que el navegador recuerde la contraseña.
- Cámbiela **apenas sospeche** que otra persona la conoce.

3.4 Si olvidó su contraseña o necesita cambiarla

1. En la pantalla de ingreso, haga clic en **¿Olvidaste tu contraseña?**.
2. Escriba su **Usuario** y el **Correo vinculado a su cuenta**, y presione **Enviar enlace**.
3. Abra el enlace que llega a su correo. Vale **24 horas** y se puede usar **una sola vez**.
4. Escriba la **Nueva contraseña**, repítala en **Confirmar contraseña** y presione **Guardar contraseña**. Ingrese con la nueva.

Por seguridad, el sistema responde lo mismo exista o no el usuario, y envía como máximo 3 correos por cuenta cada hora.

4. Qué puede ver cada persona

Cada usuario tiene un **rol** según su función. El menú muestra solo las pantallas que ese rol tiene permitidas y, dentro de algunas pantallas, el rol puede tener permitido o no crear, editar o anular. Así cada persona accede únicamente a la información que necesita para su trabajo.

Rol	Trabaja principalmente con
Recepción	Pacientes, agenda médica, citas y lista de espera, además de los reportes y la auditoría de agendamiento
Clínico	Su agenda, consultas, historia clínica, PEI y fichas médicas; la agenda médica en solo lectura; sus propios cambios en la auditoría
Ventas	Pedidos, presupuestos, caja, facturas, remisiones, notas de crédito y débito, cuentas a cobrar, cobranzas, recaudaciones y libro de ventas
Administrador	Todo lo anterior, más usuarios, funcionarios, permisos, menú, catálogos, timbrados y puntos de expedición
Superadministrador	La configuración técnica del sistema y la baja de usuarios. No participa de la gestión clínica

Los permisos exactos de cada rol los define el administrador y pueden cambiar. En **Ventas**, además, solo el Administrador y el Superadministrador pueden anular documentos.

> **Nota:** Si no ve una opción que necesita para su trabajo, pídasela al administrador. Es normal: el sistema muestra solo lo permitido para su rol.

5. Su sesión y su computadora

- **Cierre la sesión al terminar**: haga clic en su nombre, arriba a la derecha, y elija **Cerrar Sesión**.
- Si se levanta de la computadora, aunque sea un momento, **bloquéela** con las teclas **Windows + L**. Para volver, ingrese la clave de Windows.
- Si se olvida, el sistema cierra la sesión solo después de **20 minutos sin uso**, y en todo caso una sesión dura como máximo 60 minutos. Lo que ya guardó no se pierde; lo que estaba escribiendo y no guardó, sí.
- El sistema permite **una sola sesión abierta por usuario**: no use su usuario en dos equipos a la vez ni deje que otra persona lo use.
- No deje la pantalla con datos de pacientes a la vista de las personas que esperan en recepción.

6. Cómo cuidar la información

6.1 Un usuario por persona

Cada persona debe usar **solo su propio usuario**. El sistema registra quién hace cada operación: si alguien usa su usuario, todo lo que haga queda registrado a su nombre.

6.2 Datos que no se deben cargar

- Contraseñas, claves ni datos personales que no correspondan, en los campos de observaciones.
- Números completos de tarjetas de crédito o débito, ni su código de seguridad: el sistema no los necesita.

6.3 Informes y documentos

- Los informes exportados a PDF o Excel, las facturas y las recetas contienen datos de pacientes. No los envíe por WhatsApp ni a correos personales, y no los guarde en pendrives propios.
- Borre los archivos descargados cuando ya no los necesite.
- Los papeles impresos con datos de pacientes no van a la basura común: rómpalos o guárdelos.

6.4 Correos falsos

El sistema solo le envía tres tipos de correo:

- El **código de verificación**, cuando usted inicia sesión.
- El **enlace para cambiar la contraseña**, cuando usted lo pide.
- El **aviso de cuenta bloqueada**.

A los administradores, además, les llegan las alertas de anulaciones y de cambios fuera de horario, y el informe semanal.

> **Nota:** El sistema **nunca** le va a pedir su contraseña por correo, mensaje o teléfono. Si recibe un pedido así, es un intento de engaño: no responda, no haga clic en ningún enlace y avise al administrador.

6.5 Todo queda registrado

El sistema anota los ingresos (correctos y fallidos) y cada alta, modificación o anulación de datos, con el usuario, la fecha y la hora. Las facturas, las órdenes y otros registros importantes no se borran: se **anulan** indicando un motivo. Revise bien antes de confirmar una anulación.

7. Validación de los datos que se cargan

Antes de guardar, el sistema revisa cada dato. Si algo no cumple una regla, **no se guarda nada** y aparece un aviso que dice qué corregir; lo que ya estaba escrito no se pierde. Los avisos son de pocos tipos y dicen lo mismo en todas las pantallas.

7.1 Cómo se controla: tres capas

Capa	Qué hace
1. En la pantalla	Revisa los datos al presionar Guardar y avisa al instante. Es una ayuda para el usuario, pero no alcanza sola
2. En el servidor	Vuelve a revisar **todos** los datos, aunque la pantalla ya lo haya hecho. Es el control que no se puede saltear
3. En la base de datos	Controla los campos obligatorios y los valores únicos, como la cédula. Las consultas son **parametrizadas**: el dato nunca se mezcla con la instrucción SQL, lo que impide la inyección SQL. Además, todo formulario lleva protección contra formularios falsificados (CSRF)

7.2 Tipos de aviso

Tipo	Cuándo aparece	Ejemplo del mensaje	Qué hacer
Campo obligatorio	Dejó vacío un dato que el sistema necesita para guardar.	El campo "Descripción" es obligatorio.	Complete el campo que nombra el aviso y presione Guardar de nuevo.
Caracteres no permitidos	El dato trae símbolos o un formato que ese campo no admite.	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números y espacios.	Quite los símbolos; el aviso indica qué sí se puede escribir en ese campo.
El dato ya existe	Ese dato ya está cargado y no se puede repetir.	Ya existe una especialidad "PSICOLOGÍA".	Búsquelo en el listado y edítelo, o use otro valor.
Valor fuera de lo permitido	El número o la fecha no cumple la condición de la operación.	El fin del bloqueo debe ser posterior al inicio.	Corrija el valor según lo que indica el aviso.
Operación no permitida en este momento	El registro está en un estado que no admite esa acción (por	Una cita en estado 'Confirmada' no puede pasar a	Revise el estado del registro; el aviso explica qué falta

Tipo	Cuándo aparece	Ejemplo del mensaje	Qué hacer
	ejemplo, ya anulado o con la caja cerrada).	'COMPLETADA'.	resolver antes.

Un aviso que no encaja en ninguno de estos tipos es una regla propia de la pantalla (por ejemplo, una cita sin turno libre o una caja que no está abierta). El aviso siempre dice qué falta.

7.3 Dónde ver el detalle

Los avisos de cada pantalla están en los capítulos «Validaciones de…» de este manual. Las capturas de cada tipo de aviso están en el anexo del Manual de usuario.

8. Si algo no está bien

Situación	Qué hacer
Me llegó un código o un aviso de bloqueo que yo no pedí	Avise al administrador ese mismo día y cambie su contraseña
Creo que alguien conoce mi contraseña	Cámbiela de inmediato con **¿Olvidaste tu contraseña?** y avise al administrador
Mi cuenta está bloqueada	Espere: el primer bloqueo dura 30 minutos y el segundo, 1 hora. Si el bloqueo no se levanta o no fue usted quien se equivocó, avise al administrador
Veo datos o movimientos que yo no cargué con mi usuario	No los modifique. Avise al administrador para que revise el registro de actividad
Recibí un correo o una llamada pidiendo mi contraseña	No responda ni haga clic en enlaces. Avise al administrador
Perdí el acceso a mi correo	Avise al administrador: sin su correo no recibe los códigos y no puede ingresar hasta que el administrador revoque la verificación en dos pasos y vincule otro correo
La computadora se comporta de forma extraña (ventanas raras, lentitud repentina)	Cierre la sesión, no siga trabajando en ella y avise

Nota: Ante la duda, avise. Un aviso a tiempo evita problemas mayores, y nadie va a culpar a quien reporta algo que resultó no ser grave.

9. Copias de respaldo

Una copia de respaldo es una copia de toda la información del sistema, guardada aparte. Si el servidor se rompe, lo roban o los datos se dañan, con la copia se recupera todo hasta un día antes como máximo.

9.1 Cómo funciona

- Se hace **automáticamente cada 24 horas**, y una más cada vez que arranca el servicio de respaldo.
- Cada copia se guarda **cifrada**: sin la clave privada nadie puede leerla, ni siquiera quien se lleve el servidor.
- Se conservan las copias de los **últimos 14 días**; las más viejas se borran solas.
- Antes de cada migración, actualización o despliegue, el soporte técnico hace además una copia manual.

9.2 Lo que depende de usted

- **La clave privada de respaldo y su contraseña.** Guárdelas por separado y fuera del servidor (por ejemplo, un USB y un gestor de contraseñas). Sin ellas, ninguna copia se puede recuperar. Conviene tener dos copias de la clave privada en lugares distintos.
- **Una copia fuera del equipo.** Se recomienda copiar los respaldos una vez por semana a un disco externo o a la nube. Como están cifrados, pueden guardarse en la nube sin exponer datos.
- **La prueba de restauración.** Pida al soporte técnico que pruebe la recuperación de una copia **una vez por mes**, y antes de cada entrega o despliegue.

> **Nota:** Una copia que nunca se probó no se sabe si sirve. La prueba de restauración se hace sobre una base de prueba y no toca los datos reales.

Los comandos para hacer una copia manual, probar y restaurar están en el Manual de infraestructura, capítulo «Backups y restauración».

10. Calendario de tareas

Cuándo	Tarea	Quién
Cuando alguien deja de trabajar en la clínica	Pedir al Superadministrador que desactive su usuario	Administrador
Cada vez que llega un correo de cuenta bloqueada	Revisar en Auditoría si los intentos fueron de la propia persona, antes de desbloquear	Administrador
Cada vez que llega una alerta por correo	Revisar la anulación o el cambio fuera de horario que se informa	Administrador
Cada lunes	Leer el informe semanal de auditoría (llega por correo a las 07:00)	Administrador
Cada semana (recomendado)	Copiar los respaldos a un disco externo o a la nube	Administrador o soporte técnico
Cada mes	Chequeo de seguridad periódico (lista del capítulo «Auditoría y chequeo periódico»)	Soporte técnico
Cada mes	Revisar los bloqueos repetidos de una misma cuenta y las ráfagas de intentos fallidos desde un mismo equipo	Administrador
Cada mes	Prueba de restauración de una copia de respaldo	Soporte técnico
Cada 60 días	Renovar el certificado de HTTPS del servidor	Soporte técnico
Cada 90 días	Cambiar la contraseña: el sistema la vence y la pide	Todo el personal
Cada 6 meses	Cambiar las contraseñas de servicio de la base de datos (la de la aplicación y la del administrador de la base)	Soporte técnico
Cada 6 meses, o después de un incidente	Revisar este manual y que cada usuario activo siga trabajando en la clínica	Administrador

El detalle técnico de cada tarea del soporte está en el Manual de infraestructura y en los últimos capítulos de este manual.

11. Qué hacer ante un incidente

Un incidente es cualquier situación en la que la información pudo quedar expuesta o dañada: un acceso que nadie reconoce, una contraseña revelada, una computadora robada, datos borrados o modificados sin explicación, o el sistema caído.

1. **Frenar:** en el detalle del usuario afectado (pantalla Usuarios), cierre sus sesiones y revoque su verificación en dos pasos. Si hay que desactivar la cuenta, pídaselo al Superadministrador.
2. **Avisar:** comuníquese con el soporte técnico lo antes posible.
3. **Revisar:** con Auditoría, identifique qué se hizo, cuándo y desde qué equipo.
4. **Recuperar:** si se dañaron datos, el soporte técnico restaura la última copia de respaldo.
5. **Registrar:** anote la fecha, qué pasó, qué datos se vieron afectados y qué se hizo.

Fecha	Qué pasó	Datos afectados	Acciones tomadas

Advertencia: Si se robó o se perdió la computadora del servidor, avise al soporte técnico de inmediato: hay que cambiar las claves internas del sistema, lo que además cierra todas las sesiones abiertas.

Las fases, los casos frecuentes y los comandos están en el capítulo «Respuesta a incidentes».

12. Validaciones de Personas

12.1 Funcionarios

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	Debe seleccionar al menos una especialidad	Campo obligatorio
Al guardar (crear y editar)	Debe seleccionar al menos una especialidad.	Campo obligatorio
Al guardar (crear y editar)	El campo "Apellido" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Cargo" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Cédula" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Nombre" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Teléfono" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El nombre y el apellido solo pueden contener letras, espacios, guion y apóstrofe.	Regla propia de la pantalla
Al guardar (crear y editar)	La matrícula es obligatoria para especialistas.	Campo obligatorio
Regla del sistema	Matrícula es obligatoria para especialistas	Campo obligatorio
Regla del sistema	Ya existe un especialista registrado con la matrícula "…".	El dato ya existe
Regla del sistema	Ya existe una persona registrada con la cédula "…".	El dato ya existe
Regla del sistema	… tiene … cita(s) pendiente(s) (próxima: …). Cancélelas o reagéndelas con otro especialista antes de darlo de baja.	Operación no permitida en este momento

12.2 Pacientes

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	Debe indicar el número de RUC.	Campo obligatorio
Al guardar (crear y editar)	El campo "Apellido" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Cédula" es	Campo obligatorio

Cuándo	Aviso que muestra el sistema	Tipo
	obligatorio.	
Al guardar (crear y editar)	El campo "Fecha de nacimiento" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Nombre" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El nombre y el apellido solo pueden contener letras, espacios, guion y apóstrofe.	Regla propia de la pantalla
Regla del sistema	Faltan campos obligatorios: nombre, apellido, cédula y fecha de nacimiento.	Valor fuera de lo permitido
Regla del sistema	Historia clínica duplicada: …	El dato ya existe
Al editar	No se pudo actualizar el paciente.	Regla propia de la pantalla
Al crear	No se pudo crear el paciente.	Regla propia de la pantalla
Regla del sistema	Tipo de documento inválido. Debe ser CI o RUC.	Caracteres no permitidos
Regla del sistema	Ya existe una persona registrada con la cédula "…".	El dato ya existe

12.3 Usuarios

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El campo "Contraseña" es obligatorio.	Campo obligatorio
Al crear	El campo "Funcionario" es obligatorio.	Campo obligatorio
Al crear	El campo "Rol" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Username" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Las contraseñas no coinciden.	Regla propia de la pantalla
Al editar	No se pudo actualizar el usuario. Verifique que el username no esté en uso.	Regla propia de la pantalla
Al crear	No se pudo crear el usuario. Verifique que el username no exista o que el funcionario no tenga ya un usuario asignado.	Regla propia de la pantalla
Al editar	No se pudo resetear los intentos.	Regla propia de la pantalla

13. Validaciones de Agendamiento

13.1 Agenda Medica

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	'En consulta' se registra con 'Iniciar consulta', no con una corrección.	Regla propia de la pantalla
Regla del sistema	Debe seleccionar al menos una especialidad	Campo obligatorio
Al crear	El bloqueo tiene que terminar en el futuro.	Regla propia de la pantalla
Al crear	El campo "Motivo del bloqueo" es obligatorio.	Campo obligatorio
Regla del sistema	El especialista no tiene agendas cargadas.	Regla propia de la pantalla
Regla del sistema	El especialista no tiene esa especialidad	Regla propia de la pantalla
Al crear	El fin del bloqueo debe ser posterior al inicio.	Regla propia de la pantalla
Regla del sistema	El motivo de la corrección es obligatorio.	Campo obligatorio
Regla del sistema	El slot indicado no existe	Regla propia de la pantalla
Regla del sistema	El slot ya no está disponible	Regla propia de la pantalla
Regla del sistema	El sobreturno tiene que ser en el futuro.	Regla propia de la pantalla
Regla del sistema	El turno de esta cita ya no está libre (lo tomó otra cita o se quitó de la agenda). Agende una cita nueva.	Regla propia de la pantalla
Regla del sistema	El turno indicado no existe	Regla propia de la pantalla
Regla del sistema	El turno seleccionado no corresponde al especialista de la cita	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya no está disponible	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya pasó; elija un turno futuro	Regla propia de la pantalla
Regla del sistema	Ese día el especialista no atiende en esta agenda.	Regla propia de la pantalla
Regla del sistema	Ese horario está bloqueado (…).	Operación no permitida en este momento
Regla del sistema	Estado '…' no encontrado	Operación no permitida en este momento
Al crear	Indique la fecha y hora de inicio y de fin del bloqueo.	Valor fuera de lo permitido
Al crear	Indique la fecha y la hora del sobreturno.	Valor fuera de lo permitido

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	La agenda está desactivada.	Regla propia de la pantalla
Regla del sistema	La agenda indicada no existe.	Regla propia de la pantalla
Regla del sistema	La agenda no permite sobreturnos: configure el % de sobreturnos en la agenda.	Regla propia de la pantalla
Regla del sistema	La cita indicada no existe	Regla propia de la pantalla
Regla del sistema	La cita sigue abierta: use las acciones normales (Editar o cambiar estado).	Operación no permitida en este momento
Regla del sistema	La fecha está fuera de la vigencia de la agenda.	Valor fuera de lo permitido
Regla del sistema	Matrícula es obligatoria para especialistas	Campo obligatorio
Regla del sistema	No hay cambios para guardar.	Regla propia de la pantalla
Regla del sistema	No se puede editar una cita en estado '…'	Operación no permitida en este momento
Al crear	Seleccione el especialista.	Regla propia de la pantalla
Regla del sistema	Ya existe un especialista registrado con la matrícula "…".	El dato ya existe
Al guardar (crear y editar)	Ya existe un horario que se superpone para ese especialista o consultorio en ese día.	El dato ya existe
Regla del sistema	Ya existe un turno a esa hora en esta agenda.	El dato ya existe
Regla del sistema	Ya existe una empresa configurada	El dato ya existe
Regla del sistema	Ya existe una persona registrada con la cédula "…".	El dato ya existe
Regla del sistema	Ya se usaron los … sobreturno(s) permitidos para ese día.	Regla propia de la pantalla
Regla del sistema	… tiene … cita(s) pendiente(s) (próxima: …). Cancélelas o reagéndelas con otro especialista antes de darlo de baja.	Operación no permitida en este momento

13.2 Citas

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	'En consulta' se registra con 'Iniciar consulta', no con una corrección.	Regla propia de la pantalla
Regla del sistema	Debe seleccionar al menos	Campo obligatorio

Cuándo	Aviso que muestra el sistema	Tipo
	una especialidad	
Al crear	El campo "Motivo de la corrección" es obligatorio.	Campo obligatorio
Al editar	El campo "Motivo" es obligatorio.	Campo obligatorio
Al crear	El campo "Paciente" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Turno" es obligatorio.	Campo obligatorio
Regla del sistema	El especialista no tiene esa especialidad	Regla propia de la pantalla
Regla del sistema	El motivo de la corrección es obligatorio.	Campo obligatorio
Al crear	El paciente no tiene teléfono registrado.	Regla propia de la pantalla
Regla del sistema	El slot indicado no existe	Regla propia de la pantalla
Regla del sistema	El slot ya no está disponible	Regla propia de la pantalla
Regla del sistema	El turno de esta cita ya no está libre (lo tomó otra cita o se quitó de la agenda). Agende una cita nueva.	Regla propia de la pantalla
Regla del sistema	El turno indicado no existe	Regla propia de la pantalla
Regla del sistema	El turno seleccionado no corresponde al especialista de la cita	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya no está disponible	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya pasó; elija un turno futuro	Regla propia de la pantalla
Regla del sistema	Estado '…' no encontrado	Operación no permitida en este momento
Al guardar (crear y editar)	Estado inválido. Valores permitidos: ….	Caracteres no permitidos
Regla del sistema	La cita indicada no existe	Regla propia de la pantalla
Regla del sistema	La cita sigue abierta: use las acciones normales (Editar o cambiar estado).	Operación no permitida en este momento
Regla del sistema	Matrícula es obligatoria para especialistas	Campo obligatorio
Regla del sistema	No hay cambios para guardar.	Regla propia de la pantalla
Regla del sistema	No se puede editar una cita en estado '…'	Operación no permitida en este momento
Regla del sistema	Ya existe un especialista registrado con la matrícula "…".	El dato ya existe
Regla del sistema	Ya existe una persona registrada con la cédula "…".	El dato ya existe
Regla del sistema	… tiene … cita(s)	Operación no permitida en

Cuándo	Aviso que muestra el sistema	Tipo
	pendiente(s) (próxima: …). Cancélelas o reagéndelas con otro especialista antes de darlo de baja.	este momento

13.3 Lista de Espera

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El campo "Horario" es obligatorio.	Campo obligatorio
Al crear	El campo "Paciente" es obligatorio.	Campo obligatorio
Regla del sistema	Estado inválido. Valores permitidos: ….	Caracteres no permitidos

14. Validaciones de Clínico

14.1 Consultas

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	'En consulta' se registra con 'Iniciar consulta', no con una corrección.	Regla propia de la pantalla
Al crear	Cada ítem debe indicar tipo ESTUDIO o ANALISIS.	Campo obligatorio
Regla del sistema	Debe seleccionar al menos una especialidad	Campo obligatorio
Al crear	El campo "Descripción del tratamiento" es obligatorio.	Campo obligatorio
Al crear	El campo "Diagnóstico" es obligatorio.	Campo obligatorio
Al crear	El campo "Especialidad de destino" es obligatorio.	Campo obligatorio
Al editar	El campo "Estado de la consulta" es obligatorio.	Campo obligatorio
Al crear	El campo "Fecha de inicio" es obligatorio.	Campo obligatorio
Al editar	El campo "Fecha de la consulta" es obligatorio.	Campo obligatorio
Al crear	El campo "Fecha de la orden" es obligatorio.	Campo obligatorio
Al crear	El campo "Fecha de la receta" es obligatorio.	Campo obligatorio
Al crear	El campo "Fecha del certificado" es obligatorio.	Campo obligatorio
Al crear	El campo "Insumo" es obligatorio.	Campo obligatorio
Al crear	El campo "Motivo de derivación" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Motivo de la consulta" es obligatorio.	Campo obligatorio
Al crear	El campo "Motivo del certificado" es obligatorio.	Campo obligatorio
Al crear	El campo "Signo" es obligatorio.	Campo obligatorio
Al crear	El campo "Síntoma" es obligatorio.	Campo obligatorio
Al crear	El campo "Tipo de certificado" es obligatorio.	Campo obligatorio
Al crear	El campo "Tipo de procedimiento" es obligatorio.	Campo obligatorio
Al crear	El campo "Tipo de	Campo obligatorio

Cuándo	Aviso que muestra el sistema	Tipo
	tratamiento" es obligatorio.	
Regla del sistema	El especialista no tiene esa especialidad	Regla propia de la pantalla
Al crear	El informante debe ser uno de: ….	Regla propia de la pantalla
Regla del sistema	El motivo de la corrección es obligatorio.	Campo obligatorio
Regla del sistema	El slot indicado no existe	Regla propia de la pantalla
Regla del sistema	El slot ya no está disponible	Regla propia de la pantalla
Regla del sistema	El turno de esta cita ya no está libre (lo tomó otra cita o se quitó de la agenda). Agende una cita nueva.	Regla propia de la pantalla
Regla del sistema	El turno indicado no existe	Regla propia de la pantalla
Regla del sistema	El turno seleccionado no corresponde al especialista de la cita	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya no está disponible	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya pasó; elija un turno futuro	Regla propia de la pantalla
Regla del sistema	Estado '…' no encontrado	Operación no permitida en este momento
Al crear	Indique la dosis en cada ítem.	Regla propia de la pantalla
Al crear	Indique la frecuencia en cada ítem.	Regla propia de la pantalla
Al crear	La cantidad debe ser mayor a cero.	Valor fuera de lo permitido
Regla del sistema	La cita indicada no existe	Regla propia de la pantalla
Regla del sistema	La cita sigue abierta: use las acciones normales (Editar o cambiar estado).	Operación no permitida en este momento
Al crear	La orden debe tener al menos un ítem de estudio o análisis.	Campo obligatorio
Al crear	La receta debe tener al menos un medicamento.	Campo obligatorio
Regla del sistema	Matrícula es obligatoria para especialistas	Campo obligatorio
Regla del sistema	No hay cambios para guardar.	Regla propia de la pantalla
Regla del sistema	No se puede editar una cita en estado '…'	Operación no permitida en este momento
Al crear	No se puede iniciar una consulta para una cita en estado "…".	Operación no permitida en este momento
Al crear	Seleccione el medicamento en cada ítem.	Regla propia de la pantalla
Al crear	Seleccione el tipo de análisis en cada ítem.	Regla propia de la pantalla

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Seleccione el tipo de estudio en cada ítem.	Regla propia de la pantalla
Regla del sistema	Stock insuficiente para registrar este insumo.	Regla propia de la pantalla
Regla del sistema	Ya existe un especialista registrado con la matrícula "…".	El dato ya existe
Regla del sistema	Ya existe una persona registrada con la cédula "…".	El dato ya existe
Regla del sistema	… tiene … cita(s) pendiente(s) (próxima: …). Cancélelas o reagéndelas con otro especialista antes de darlo de baja.	Operación no permitida en este momento

14.2 PEI

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Estado inválido. Debe ser ACTIVO o CERRADO.	Caracteres no permitidos
Al crear	No se pudo determinar el especialista. Verificá tu perfil.	Regla propia de la pantalla

14.3 Fichas Medicas

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El contenido de la nota no puede estar vacío.	Campo obligatorio
Al crear	No se pudo determinar el especialista. Verificá tu perfil.	Regla propia de la pantalla

15. Validaciones de Ventas

15.1 Pedidos

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Cada ítem debe tener una cantidad mayor a 0.	Valor fuera de lo permitido
Al crear	Cada ítem debe tener una descripción.	Regla propia de la pantalla
Al crear	El campo "Fecha del pedido" es obligatorio.	Campo obligatorio
Al crear	El campo "Paciente" es obligatorio.	Campo obligatorio
Al crear	El pedido debe tener al menos un ítem.	Campo obligatorio
Al editar	Estado inválido.	Caracteres no permitidos

15.2 Presupuestos

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	'En consulta' se registra con 'Iniciar consulta', no con una corrección.	Regla propia de la pantalla
Al crear	Cada ítem debe tener una cantidad mayor a 0.	Valor fuera de lo permitido
Al crear	Cada ítem debe tener una descripción.	Regla propia de la pantalla
Al crear	El campo "Fecha del presupuesto" es obligatorio.	Campo obligatorio
Al crear	El campo "Paciente" es obligatorio.	Campo obligatorio
Regla del sistema	El especialista no tiene esa especialidad	Regla propia de la pantalla
Regla del sistema	El motivo de la corrección es obligatorio.	Campo obligatorio
Regla del sistema	El plan de tratamiento (PEI) indicado no corresponde al paciente.	Regla propia de la pantalla
Al crear	El presupuesto debe tener al menos un ítem.	Campo obligatorio
Regla del sistema	El slot indicado no existe	Regla propia de la pantalla
Regla del sistema	El slot ya no está disponible	Regla propia de la pantalla
Regla del sistema	El turno de esta cita ya no está libre (lo tomó otra cita o se quitó de la agenda).	Regla propia de la pantalla

Cuándo	Aviso que muestra el sistema	Tipo
	Agende una cita nueva.	
Regla del sistema	El turno indicado no existe	Regla propia de la pantalla
Regla del sistema	El turno seleccionado no corresponde al especialista de la cita	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya no está disponible	Regla propia de la pantalla
Regla del sistema	El turno seleccionado ya pasó; elija un turno futuro	Regla propia de la pantalla
Regla del sistema	Estado '…' no encontrado	Operación no permitida en este momento
Al editar	Estado inválido.	Caracteres no permitidos
Regla del sistema	La cita indicada no existe	Regla propia de la pantalla
Regla del sistema	La cita sigue abierta: use las acciones normales (Editar o cambiar estado).	Operación no permitida en este momento
Regla del sistema	No hay cambios para guardar.	Regla propia de la pantalla
Regla del sistema	No se encontró el presupuesto.	Regla propia de la pantalla
Regla del sistema	No se puede editar una cita en estado '…'	Operación no permitida en este momento
Regla del sistema	Solo se puede convertir en pedido un presupuesto aprobado.	Regla propia de la pantalla

15.3 Estado de Caja

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El campo "Caja" es obligatorio.	Campo obligatorio
Al crear	El campo "Saldo final" es obligatorio.	Campo obligatorio
Al crear	El campo "Usuario" es obligatorio.	Campo obligatorio
Regla del sistema	La caja ya tiene una apertura activa (ID …).	Regla propia de la pantalla

15.4 Historial de Caja

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El campo "Caja" es obligatorio.	Campo obligatorio
Al crear	El campo "Saldo final" es	Campo obligatorio

Cuándo	Aviso que muestra el sistema	Tipo
	obligatorio.	
Al crear	El campo "Usuario" es obligatorio.	Campo obligatorio
Regla del sistema	La caja ya tiene una apertura activa (ID …).	Regla propia de la pantalla

15.5 Arqueos de Caja

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El campo "Apertura de caja" es obligatorio.	Campo obligatorio
Al crear	El campo "Caja" es obligatorio.	Campo obligatorio
Al crear	El campo "Monto real" es obligatorio.	Campo obligatorio
Regla del sistema	No se encontró la apertura de caja especificada.	Regla propia de la pantalla

15.6 Facturas

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Cada ítem debe tener una descripción.	Regla propia de la pantalla
Al editar	Debe indicar el motivo de la anulación.	Campo obligatorio
Al crear	El campo "Condición de venta" es obligatorio.	Campo obligatorio
Al crear	El campo "Estado de la factura" es obligatorio.	Campo obligatorio
Al crear	El campo "Fecha de la factura" es obligatorio.	Campo obligatorio
Al crear	El campo "Paciente" es obligatorio.	Campo obligatorio
Al crear	El campo "Precio de cada ítem" es obligatorio.	Campo obligatorio
Al crear	El campo "Punto de expedición" es obligatorio.	Campo obligatorio
Al crear	El campo "Timbrado" es obligatorio.	Campo obligatorio
Al crear	El campo "Tipo de comprobante" es obligatorio.	Campo obligatorio
Regla del sistema	El descuento no puede ser negativo ni mayor al total de	Valor fuera de lo permitido

Cuándo	Aviso que muestra el sistema	Tipo
	la factura.	
Regla del sistema	Elija la forma de cobro de la factura al contado.	Regla propia de la pantalla
Al crear	La caja elegida no está abierta. Ábrala en Estado de Caja antes de facturar al contado.	Operación no permitida en este momento
Regla del sistema	La caja ya tiene una apertura activa (ID …).	Regla propia de la pantalla
Al crear	La cantidad de cada ítem debe ser mayor a 0.	Valor fuera de lo permitido
Al crear	La factura debe tener al menos un ítem en el detalle.	Campo obligatorio
Al editar	La factura ya está anulada o no se pudo anular.	Operación no permitida en este momento
Regla del sistema	Las formas de cobro deben sumar el total de la factura.	Regla propia de la pantalla
Regla del sistema	Monto fuera de rango para numero_a_letras: …	Valor fuera de lo permitido
Regla del sistema	Para facturar al contado elija la caja donde entra el cobro.	Regla propia de la pantalla
Regla del sistema	Punto de expedición no encontrado.	Regla propia de la pantalla

15.7 Remisiones

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Cada ítem debe tener una descripción.	Regla propia de la pantalla
Al crear	El campo "Fecha de la remisión" es obligatorio.	Campo obligatorio
Al crear	El campo "Paciente" es obligatorio.	Campo obligatorio
Al crear	La cantidad de cada ítem debe ser mayor a 0.	Valor fuera de lo permitido
Al crear	La remisión debe tener al menos un ítem en el detalle.	Campo obligatorio
Al editar	La remisión ya está anulada.	Operación no permitida en este momento
Al editar	La remisión ya fue entregada o no se puede cambiar su estado.	Operación no permitida en este momento

15.8 Notas de Credito

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Cada ítem debe tener una descripción.	Regla propia de la pantalla
Al crear	El campo "Factura" es obligatorio.	Campo obligatorio
Al crear	El campo "Motivo" es obligatorio.	Campo obligatorio
Regla del sistema	El descuento no puede ser negativo ni mayor al total de la factura.	Valor fuera de lo permitido
Regla del sistema	Elija la forma de cobro de la factura al contado.	Regla propia de la pantalla
Regla del sistema	La factura debe tener al menos un ítem en el detalle.	Campo obligatorio
Regla del sistema	La factura indicada no existe.	Regla propia de la pantalla
Al crear	La nota de crédito debe tener al menos un ítem.	Campo obligatorio
Al editar	La nota ya está anulada o no se pudo anular.	Operación no permitida en este momento
Regla del sistema	Las formas de cobro deben sumar el total de la factura.	Regla propia de la pantalla
Regla del sistema	Monto fuera de rango para numero_a_letras: …	Valor fuera de lo permitido
Regla del sistema	Para facturar al contado elija la caja donde entra el cobro.	Regla propia de la pantalla
Regla del sistema	Punto de expedición no encontrado.	Regla propia de la pantalla

15.9 Notas de Debito

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Cada ítem debe tener una descripción.	Regla propia de la pantalla
Al crear	El campo "Factura" es obligatorio.	Campo obligatorio
Al crear	El campo "Motivo" es obligatorio.	Campo obligatorio
Regla del sistema	El descuento no puede ser negativo ni mayor al total de la factura.	Valor fuera de lo permitido
Regla del sistema	Elija la forma de cobro de la factura al contado.	Regla propia de la pantalla
Regla del sistema	La factura debe tener al menos un ítem en el detalle.	Campo obligatorio
Regla del sistema	La factura indicada no existe.	Regla propia de la pantalla

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	La nota de débito debe tener al menos un ítem.	Campo obligatorio
Al editar	La nota ya está anulada o no se pudo anular.	Operación no permitida en este momento
Regla del sistema	Las formas de cobro deben sumar el total de la factura.	Regla propia de la pantalla
Regla del sistema	Monto fuera de rango para numero_a_letras: …	Valor fuera de lo permitido
Regla del sistema	Para facturar al contado elija la caja donde entra el cobro.	Regla propia de la pantalla
Regla del sistema	Punto de expedición no encontrado.	Regla propia de la pantalla

15.10 Cobranzas

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	Cada línea de detalle requiere una forma de cobro.	Regla propia de la pantalla
Regla del sistema	Cobranza no encontrada.	Regla propia de la pantalla
Al crear	Debe agregar al menos una forma de cobro.	Regla propia de la pantalla
Al crear	El campo "Caja" es obligatorio.	Campo obligatorio
Al crear	El campo "Cuenta a cobrar" es obligatorio.	Campo obligatorio
Al crear	El campo "Factura" es obligatorio.	Campo obligatorio
Al crear	El monto de cada forma de cobro debe ser mayor a 0.	Valor fuera de lo permitido
Regla del sistema	El monto total cobrado debe ser mayor a cero.	Valor fuera de lo permitido
Regla del sistema	Esta cuenta ya está completamente cobrada.	Regla propia de la pantalla
Regla del sistema	La cobranza debe tener al menos una forma de cobro.	Campo obligatorio
Al editar	La cobranza ya está anulada o no se encontró.	Operación no permitida en este momento
Regla del sistema	La cuenta a cobrar está anulada (la factura fue anulada).	Operación no permitida en este momento
Regla del sistema	La cuenta a cobrar no existe.	Regla propia de la pantalla
Regla del sistema	La cuenta a cobrar, la factura y la caja son obligatorias.	Regla propia de la pantalla
Regla del sistema	La moneda de la caja no coincide con la de la cuenta a cobrar.	Regla propia de la pantalla

Cuándo	Aviso que muestra el sistema	Tipo
Regla del sistema	No hay caja abierta. Debe abrir la caja antes de registrar una cobranza.	Regla propia de la pantalla

15.11 Recaudaciones

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El campo "Caja" es obligatorio.	Campo obligatorio
Al crear	El campo "Depósito" es obligatorio.	Campo obligatorio
Al editar	El campo "Fecha de depósito" es obligatorio.	Campo obligatorio
Regla del sistema	El monto total de la recaudación debe ser mayor a cero.	Valor fuera de lo permitido
Al crear	El monto total debe ser mayor a cero.	Valor fuera de lo permitido
Regla del sistema	La caja y el depósito son obligatorios.	Regla propia de la pantalla
Al editar	La recaudación ya está anulada o no se encontró.	Operación no permitida en este momento
Regla del sistema	No hay caja abierta. Debe abrir la caja antes de registrar una recaudación.	Regla propia de la pantalla
Al editar	No se pudo marcar como depositada.	Regla propia de la pantalla
Regla del sistema	Recaudación no encontrada.	Regla propia de la pantalla
Regla del sistema	Solo se pueden depositar recaudaciones en estado PENDIENTE.	Operación no permitida en este momento

16. Validaciones de Configuración

16.1 Cajas

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios, puntos y guiones.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El estado de caja debe ser uno de: ….	Operación no permitida en este momento
Al guardar (crear y editar)	El saldo inicial no puede ser negativo.	Valor fuera de lo permitido
Al guardar (crear y editar)	Ya existe una caja "…".	El dato ya existe

16.2 Cargos

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números y espacios.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El cargo "…" está reservado por el sistema.	Regla propia de la pantalla
Al guardar (crear y editar)	Ya existe un cargo "…".	El dato ya existe

16.3 Condiciones de Venta

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe una condición de venta "…".	El dato ya existe

16.4 Consultorios

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números y espacios.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Sede" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un consultorio "…" en esa sede.	El dato ya existe

16.5 Depósitos

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios, puntos y guiones.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El tipo de depósito debe ser uno de: ….	Regla propia de la pantalla
Al guardar (crear y editar)	Ya existe un depósito "…".	El dato ya existe

16.6 Diagnósticos

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El código CIE-10 no tiene un formato válido (ej. F32 o F32.1).	Valor fuera de lo permitido
Al guardar (crear y editar)	Ya existe un diagnóstico "…".	El dato ya existe
Al guardar (crear y editar)	Ya existe un diagnóstico con el código CIE-10 "…".	El dato ya existe

16.7 Empresa

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	Ya existe una empresa con el RUC/NIT "…".	El dato ya existe
Regla del sistema	Ya existe una empresa configurada	El dato ya existe
Al crear	Ya existe una empresa configurada.	El dato ya existe

16.8 Entidades Adheridas

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios, puntos y guiones.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe una entidad adherida "…".	El dato ya existe

16.9 Entidades Emisoras

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios, puntos y guiones.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe una entidad emisora "…".	El dato ya existe

16.10 Especialidades

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números y espacios.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe una especialidad "…".	El dato ya existe

16.11 Estados de Factura

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un estado de factura "…".	El dato ya existe

16.12 Formas de Cobro

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Código" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe una forma de cobro "…".	El dato ya existe
Al guardar (crear y editar)	Ya existe una forma de cobro con código "…".	El dato ya existe

16.13 Instrumentos

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un instrumento "…".	El dato ya existe

16.14 Insumos

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El precio unitario no puede ser negativo.	Valor fuera de lo permitido
Al guardar (crear y editar)	El stock actual no puede ser negativo.	Valor fuera de lo permitido
Al guardar (crear y editar)	El stock mínimo no puede ser negativo.	Valor fuera de lo permitido
Al guardar (crear y editar)	Ya existe un insumo "…".	El dato ya existe

16.15 Ítems / Servicios

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios, puntos y guiones.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Tipo de ítem" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un ítem con descripción "…".	El dato ya existe

16.16 Marcas de Tarjeta

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe una marca de tarjeta "…".	El dato ya existe

16.17 Medicamentos

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un medicamento "…".	El dato ya existe

16.18 Monedas

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Código" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe una moneda con código "…".	El dato ya existe

16.19 Sedes

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción"	Caracteres no permitidos

Cuándo	Aviso que muestra el sistema	Tipo
	contiene caracteres no permitidos. Use solo letras, números y espacios.	
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El código de establecimiento SIFEN debe tener 3 dígitos numéricos.	Regla propia de la pantalla
Al crear	No hay una empresa configurada. Configure los datos de la empresa antes de crear sedes.	Regla propia de la pantalla
Regla del sistema	Ya existe una empresa configurada	El dato ya existe
Al guardar (crear y editar)	Ya existe una sede "…".	El dato ya existe
Al guardar (crear y editar)	Ya existe una sede con el código de establecimiento "…".	El dato ya existe

16.20 Signos

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un signo "…".	El dato ya existe

16.21 Síntomas

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un síntoma "…".	El dato ya existe

16.22 Tipos de Análisis

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de análisis "…".	El dato ya existe

16.23 Tipos de Certificado Médico

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de certificado médico "…".	El dato ya existe

16.24 Tipos de Comprobante

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de comprobante "…".	El dato ya existe

16.25 Tipos de Estudio

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras,	Caracteres no permitidos

Cuándo	Aviso que muestra el sistema	Tipo
	números, espacios y puntos.	
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de estudio "…".	El dato ya existe

16.26 Tipos de Impuesto

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios, puntos y el símbolo %.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de impuesto "…".	El dato ya existe

16.27 Tipos de Ítem

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de ítem "…".	El dato ya existe

16.28 Tipos de Procedimiento

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de	El dato ya existe

Cuándo	Aviso que muestra el sistema	Tipo
	procedimiento "…".	

16.29 Tipos de Tratamiento

Cuándo	Aviso que muestra el sistema	Tipo
Al guardar (crear y editar)	El campo "Descripción" contiene caracteres no permitidos. Use solo letras, números, espacios y puntos.	Caracteres no permitidos
Al guardar (crear y editar)	El campo "Descripción" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	Ya existe un tipo de tratamiento "…".	El dato ya existe

16.30 Timbrados

Cuándo	Aviso que muestra el sistema	Tipo
Al crear	El campo "Fechas de inicio y vencimiento" es obligatorio.	Campo obligatorio
Al editar	El campo "Fechas" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El campo "Número de timbrado" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El código de establecimiento debe tener 3 dígitos numéricos.	Regla propia de la pantalla
Al guardar (crear y editar)	El número de timbrado debe tener 8 dígitos numéricos.	Regla propia de la pantalla
Al guardar (crear y editar)	La fecha de vencimiento debe ser mayor o igual a la de inicio.	Valor fuera de lo permitido
Al dar de baja	No se puede eliminar: tiene facturas asociadas.	Operación no permitida en este momento
Al editar	Ya existe otro timbrado con número "…".	El dato ya existe
Al crear	Ya existe un timbrado con número "…".	El dato ya existe

16.31 Puntos de Expedicion

Cuándo	Aviso que muestra el sistema	Tipo
Al editar	El campo "Código" es obligatorio.	Campo obligatorio
Al crear	El campo "Nombre del punto" es obligatorio.	Campo obligatorio
Al editar	El campo "Nombre" es obligatorio.	Campo obligatorio
Al crear	El campo "Timbrado" es obligatorio.	Campo obligatorio
Al guardar (crear y editar)	El código debe tener 3 dígitos numéricos.	Regla propia de la pantalla
Al crear	El código es obligatorio (3 dígitos).	Campo obligatorio
Al dar de baja	No se puede eliminar: tiene facturas asociadas.	Operación no permitida en este momento
Al guardar (crear y editar)	Ya existe el código "…" para este timbrado.	El dato ya existe

16.32 Roles y Permisos

Cuándo	Aviso que muestra el sistema	Tipo
Al editar	Cada cambio debe incluir id_modulo, id_accion y permitido.	Regla propia de la pantalla
Al editar	No se recibieron cambios para guardar.	Regla propia de la pantalla

16.33 Auditoria

Cuándo	Aviso que muestra el sistema	Tipo
Al consultar	Las fechas no tienen un formato válido.	Valor fuera de lo permitido
Al dar de baja	No se pudo cerrar la sesión	Regla propia de la pantalla

16.34 Menu

Cuándo	Aviso que muestra el sistema	Tipo
Al editar	Cada cambio debe incluir id_pagina y visible.	Regla propia de la pantalla
Al editar	No se recibieron cambios	Regla propia de la pantalla

Cuándo	Aviso que muestra el sistema	Tipo
	para guardar.	

17. Objetivo, alcance y clasificación de la información

Este manual reúne **las políticas y los controles de seguridad** de Sysclin: contraseñas y autenticación, roles y control de acceso, seguridad de la aplicación, auditoría y respuesta ante un incidente.

Los procedimientos de operación del servidor (contenedores, configuración, base de datos, despliegue y backups) están en el **Manual de infraestructura**. El trabajo diario de cada rol en agenda, consultorio y ventas lo explica el **Manual de usuario** (botón de Ayuda).

17.1 Objetivo

- **Confidencialidad**: solo accede quien debe.
- **Integridad**: los datos no se alteran sin control y queda registro de los cambios.
- **Disponibilidad**: el sistema funciona y, si algo falla, se recupera desde un backup.

17.2 Alcance

Alcanza a la aplicación web, la base de datos, los respaldos, la infraestructura donde corre (desarrollo y servidor) y a todas las personas que usan o administran el sistema.

17.3 Convenciones de este manual

- Los comandos se ejecutan en **PowerShell**, desde la **carpeta raíz del proyecto** (syscomcli), salvo que se indique otra cosa. Los marcados como bash son para el servidor Linux.
- Donde aparece <algo>, se reemplaza por el valor real, sin los signos < >.
- El texto que empieza con **Nota:** es información a tener en cuenta; el que empieza con **Advertencia:**, una acción que puede causar pérdida de datos o corte del servicio.

17.4 Clasificación de la información

Nivel	Qué incluye	Exigencias
Sensible	Historia clínica (consultas, diagnósticos, recetas, PEI, derivaciones), datos personales de pacientes, credenciales	Acceso solo por rol; cifrado en tránsito y en los respaldos; auditoría de acceso; **no se borra físicamente** (la historia clínica se conserva)
Interna	Facturación, caja, cobranzas, agenda, configuración	Acceso por rol; cifrado en tránsito y en los respaldos
Pública	Pantalla de inicio de sesión, guía de uso	Sin restricción

Nota: Como se trata de datos de salud, **el cifrado, el respaldo y la auditoría tienen prioridad sobre la comodidad**.

18. Contraseñas y autenticación

18.1 Usuarios del sistema

Regla	Valor vigente
Longitud	Entre 8 y 16 caracteres
Complejidad	Al menos 1 mayúscula, 1 minúscula, 1 número y 1 carácter especial (!@#$%^&*)
Prohibido	Igual al nombre de usuario, contener el nombre o apellido, o estar en la lista de contraseñas comunes
Vencimiento	90 días. Al vencer, el sistema exige el cambio
Historial de contraseñas	**No se guarda, por decisión de diseño** (ver más abajo)
Almacenamiento	Solo el hash (pbkdf2:sha256; algunas anteriores en scrypt, también seguro). **Nunca** la contraseña en texto, ni siquiera la de un intento fallido
Segundo factor (MFA)	Código por correo, válido 5 minutos, máximo 5 intentos por código. Tras un código correcto, el equipo queda como "dispositivo confiable" por 60 días y no se vuelve a pedir en él
Bloqueo escalonado	5 fallos → 30 min; 3 más → 1 h; 3 más → bloqueo indefinido, que solo levanta un administrador
Límite por equipo	10 fallos desde una misma IP en 15 min frenan el login desde esa IP
Recuperación	Exige usuario **y** correo registrado; enlace válido 24 h y de un solo uso; máximo 3 solicitudes por cuenta por hora; mensaje genérico (no revela si la cuenta existe)
Sesión	Máximo 60 min; se cierra tras 20 min de inactividad; 1 sesión simultánea por usuario
Cookie de sesión	HttpOnly, SameSite=Lax; en el servidor, además Secure

"**Revocar MFA**" (en **Auditoría → Sesiones y usuarios**) anula los códigos pendientes, **todos los dispositivos confiables** de la cuenta y sus sesiones abiertas.

> **Nota: Excepciones vigentes**: las cuentas de prueba lgonzalez, psicoadmin y recep tienen "la contraseña nunca expira" y no usan MFA. Se aceptan solo en desarrollo. En producción, toda cuenta vence a los 90 días y las de Administrador usan MFA.

18.2 Credenciales de servicio

Credencial	Dónde vive	Rotación
Usuario de la app en la base (sysclin_app)	.env (DB_PASSWORD)	Cada 6 meses o ante sospecha
Administrador de la base (postgres)	.env (POSTGRES_PASSWORD) y gestor de contraseñas del administrador	Cada 6 meses o ante sospecha
SECRET_KEY	.env; mínimo 32 caracteres, distinta en desarrollo y en el servidor	Ante sospecha (cambiarla cierra todas las sesiones)
Correo saliente (SMTP) y WhatsApp (UltraMsg)	.env	Según el proveedor, o ante sospecha
Clave privada del backup	**Fuera del servidor**: USB o gestor de contraseñas, con su contraseña guardada aparte	Solo si se pierde o se compromete

- Ninguna contraseña se escribe en el código ni en las migraciones.
- Las contraseñas de servicio se generan al azar, con 48 caracteres o más (Manual de infraestructura, capítulo «Configuración»).

Los procedimientos para cambiarlas están en el Manual de infraestructura, capítulo «Base de datos».

18.3 Por qué no se guarda historial de contraseñas

Muchos sistemas guardan las últimas contraseñas de cada usuario para impedir que las reutilice. Sysclin **no lo hace**; la tabla password_history se eliminó con la migración 105 (2026-10-11).

Motivo	Explicación
Es un depósito de contraseñas viejas	Si la base se filtrara, el atacante tendría varias contraseñas por persona. La gente suele reutilizar variantes en otros servicios (correo, banca). Para datos de salud, guardar menos es más seguro
No protegía nada	Cada hash lleva una sal aleatoria distinta, así que la comparación "no reutilizar las últimas 5" nunca coincidía
Hay controles mejores	Complejidad obligatoria, vencimiento a 90 días, MFA por correo y bloqueo escalonado
Coincide con las recomendaciones actuales	NIST SP 800-63B ya no recomienda reglas de "no reutilizar las últimas N"

19. Roles y control de acceso

19.1 Roles de la aplicación

Rol	Alcance
Super Administrador (SUPERADMIN)	Configuración técnica del sistema y baja de usuarios. No participa de la gestión clínica
Administrador (ADMINISTRADOR)	Usuarios, permisos, menú, accesos, auditoría y desbloqueo de cuentas
Recepción (RECEPCION)	Agenda, citas, lista de espera, pacientes
Clínico (CLINICO)	Consultas, historia clínica, recetas, órdenes, PEI, derivaciones
Ventas (VENTAS)	Caja, facturación, cobranzas, notas de crédito y débito

- **Mínimo privilegio**: cada usuario recibe solo el rol que necesita. El menú se arma por rol: qué páginas ve cada rol se configura en **Seguridad → Menú**, y qué acciones puede hacer, en **Seguridad → Permisos**.
- El alta de usuarios la hace un administrador; **no existe autoregistro ni ingreso con redes sociales**.
- La baja la hace el Super Administrador. La cuenta se **desactiva**, no se borra, para conservar su rastro en la auditoría; queda registrada como RECORD_DELETE.
- Para ver exactamente qué ve cada rol, el inicio del administrador tiene el botón **Manual de usuario**, que permite elegir el rol.

19.2 Roles de la base de datos

Rol de la base	Uso	Permisos
postgres	Administración, migraciones, backup	Superusuario
sysclin_app	La aplicación	Solo leer y escribir datos, usar secuencias y ejecutar funciones. **Sin** DROP, CREATE, TRUNCATE, ALTER, creación de roles o bases, ni tablas temporales

Si alguien aprovechara una falla de la aplicación, solo tendría los permisos de sysclin_app.

20. Seguridad de la aplicación

20.1 SECRET_KEY

- Firma la cookie de sesión de cada usuario.
- **La aplicación no arranca** si falta o tiene menos de 32 caracteres; el log muestra RuntimeError: SECRET_KEY ausente o con menos de 32 caracteres en .env.
- Cambiarla cierra la sesión de todos los usuarios. Hacerlo si se sospecha que se filtró.
- En el servidor tiene que ser **distinta** de la de desarrollo.

20.2 Cookie de sesión

```
curl.exe -sk -D - -o NUL https://localhost/login | Select-String 'Set-Cookie'
```

Atributo	Protege contra	Dónde
HttpOnly	Robo de la sesión con JavaScript	Siempre
SameSite=Lax	Peticiones falsificadas desde otros sitios	Siempre
Secure	Envío de la cookie por HTTP sin cifrar	Servidor (SESSION_COOKIE_SECURE=1)

Además, todo formulario lleva protección **CSRF**.

20.3 Modo depuración

Advertencia: FLASK_DEBUG=1 activa el depurador, que permite ejecutar código desde el navegador si ocurre un error. **Solo para desarrollo.** En el servidor, siempre FLASK_DEBUG=0.

20.4 IP de los usuarios en auditoría

```
docker exec syscomcli_bd psql -U postgres -d sysclin_bd -c "SELECT accion, ip_origen, fecha_evento FROM auditoria_sistema ORDER BY fecha_evento DESC LIMIT 10"
```

- En desarrollo, con Docker Desktop, los accesos desde la propia PC aparecen como 172.x.x.1. Es normal.
- Por HTTPS la IP **no se puede falsificar**: nginx reemplaza el encabezado X-Forwarded-For que mande el cliente. Por el puerto 5005 sí se podría; por eso en el servidor se cierra.

20.5 Bloqueo de cuentas y límites de intentos

Nivel	Se activa con	Bloqueo	Se levanta
1	5 intentos fallidos	30 minutos	Solo, al vencer el tiempo
2	3 intentos fallidos más	1 hora	Solo, al vencer el tiempo
3	3 intentos fallidos más	**Indefinido**	**Solo un administrador**

- Un inicio de sesión correcto reinicia el contador al nivel 0.
- En cada fallo el usuario ve Contraseña incorrecta. Intentos restantes: N. Al bloquearse, le llega un **correo de aviso** si tiene uno vinculado.
- Mientras la cuenta está bloqueada, **ni la contraseña correcta deja entrar**.

Límite	Regla	Qué ve el usuario	Se levanta
Por IP (login)	10 fallos desde una misma IP en 15 min, sumando todos los usuarios	Demasiados intentos fallidos desde esta IP...	Solo, a los 15 min
Recuperación de contraseña	3 correos por cuenta en 60 min	El mensaje genérico de siempre, pero no se envía otro correo	Solo, a los 60 min
Código MFA	5 intentos por código	Debe pedir un código nuevo	Al pedir otro código

20.5.1 Desbloquear una cuenta desde la aplicación

- **Auditoría** → **Sesiones y usuarios** → botón **Desbloquear** en la fila del usuario, o
- **Usuarios** → detalle del usuario → **Resetear intentos y desbloquear**.

La cuenta vuelve al **nivel 0**. Antes de desbloquear, revisar en Auditoría si los intentos fueron del propio usuario.

20.5.2 Consultas por consola

```
# Cuentas bloqueadas o con escalada activa
docker exec syscomcli_bd psql -U postgres -d sysclin_bd -c "SELECT usu_nick, nivel_escalada_bloqueo,
usu_nro_intentos, motivo_bloqueo, bloqueado_hasta FROM usuarios WHERE fecha_bloqueo IS NOT NULL OR
nivel_escalada_bloqueo > 0"

# Eventos de seguridad recientes
docker exec syscomcli_bd psql -U postgres -d sysclin_bd -c "SELECT fecha_evento, accion, host(ip_origen) AS ip,
detalle FROM auditoria_sistema WHERE accion IN ('ACCOUNT_LOCKED','ACCOUNT_UNLOCKED','RATE_LIMIT')
ORDER BY fecha_evento DESC LIMIT 20"
```

20.5.3 Desbloqueo de emergencia por consola

> **Nota:** Solo si **ningún administrador puede iniciar sesión** (por ejemplo, el único administrador quedó en el nivel 3). Reemplazar <usuario> y <tu_nombre>; el comando deja el registro en auditoría.

```
"UPDATE usuarios SET usu_nro_intentos=0, nivel_escalada_bloqueo=0, fecha_bloqueo=NULL,
bloqueado_hasta=NULL, motivo_bloqueo=NULL WHERE usu_nick='<usuario>'; INSERT INTO auditoria_sistema
(accion, detalle) VALUES ('ACCOUNT_UNLOCKED', 'Desbloqueo de emergencia por consola de <usuario>,
realizado por <tu_nombre>');" | docker exec -i syscomcli_bd psql -U postgres -d sysclin_bd -v ON_ERROR_STOP=1
```

Riesgo conocido: como el bloqueo es por cuenta, alguien que conozca un nombre de usuario puede provocar su bloqueo sin saber la contraseña. Ante bloqueos repetidos, revisar en Auditoría la IP de origen de los LOGIN_FAILED.

21. Auditoría y chequeo periódico

21.1 Qué se registra

En la tabla auditoria_sistema, con usuario, IP, fecha y detalle. Se consulta en Auditoría → pestaña **Eventos del sistema**.

Evento	Qué registra
LOGIN, LOGOUT, LOGIN_FAILED	Inicios, cierres e intentos fallidos de sesión
ACCOUNT_LOCKED, ACCOUNT_UNLOCKED	Bloqueo por intentos fallidos (con el nivel) y desbloqueo (con quién desbloqueó)
RATE_LIMIT	Una IP frenada en el login, o la recuperación de una cuenta frenada. Una vez por ventana, no en cada intento
PASSWORD_CHANGE	Cambios y reseteos de contraseña
RECORD_CREATE/UPDATE/DELETE, REPORT_VIEW/EXPORT	Operaciones sobre registros, consulta de reportes y su exportación a PDF

Además, accesos_sistema guarda cada intento de login con su resultado, IP y navegador (Auditoría → pestaña **Accesos y seguridad**).

21.2 Cambios en datos

Desde el 2026-10-19, cada alta, modificación y baja de las 40 tablas críticas (clínicas, agendamiento, ventas y seguridad) queda en auditoria_transacciones, con el **dato anterior y el nuevo**, el usuario, sus roles, la IP y la hora. Lo registra la base con un trigger; la aplicación solo puede leerlo, nunca modificarlo ni borrarlo. Las contraseñas y claves secretas se guardan como ***. Se consulta en Auditoría → pestaña **Cambios en datos**: el Administrador ve todo; el Superadministrador, todo menos lo clínico; Recepción, agendamiento; el Clínico, solo sus propios cambios; Ventas, solo cantidades.

21.3 Alertas e informe semanal

- **Alertas por correo**, cada 5 minutos, a los Administradores y Superadministradores activos con correo cargado: anulaciones (facturas, notas de crédito y débito, cobranzas) y cambios hechos fuera del horario de atención de la empresa (Referenciales → Empresa). Cada uno recibe solo lo que su rol puede ver. Quedan registradas como ALERTA_ENVIADA.
- **Informe semanal en PDF**, los lunes a las 07:00, con la semana anterior; también se descarga con el botón **Informe semanal (PDF)** de Auditoría. Queda registrado como INFORME_SEMANAL.

21.4 Chequeo de seguridad periódico

Una vez por mes, y antes de una entrega o despliegue.

#	Qué comprobar	Cómo	Esperado
1	Los contenedores están corriendo	docker ps --filter name=syscomcli	4 contenedores Up; la base, healthy
2	HTTPS activo y HTTP redirige	Manual de infraestructura, capítulo «HTTPS, red y despliegue», "Comprobar HTTPS"	301 a https; TLS 1.2/1.3; encabezados presentes
3	El certificado no está por vencer (servidor)	Manual de infraestructura, capítulo «HTTPS, red y despliegue», fecha de vencimiento	Más de 30 días restantes
4	El backup automático funciona	docker logs syscomcli_backup --tail 5	Backup creado de las últimas 24 h
5	Los backups se pueden restaurar	Prueba de restauración	RESTAURACION OK
6	No hay backups sin cifrar	Get-ChildItem backups -Filter *.dump	Ningún archivo
7	La app no usa el superusuario	docker exec syscomcli_app printenv DB_USER	sysclin_app
8	Los permisos de la app son mínimos	Manual de infraestructura, capítulo «Base de datos»	Los 3 ERROR
9	La clave por defecto no sirve	Manual de infraestructura, capítulo «Base de datos»	password authentication failed
10	La cookie es segura	Capítulo Seguridad de la aplicación	HttpOnly, SameSite=Lax (y Secure en el servidor)
11	Accesos sospechosos	**Auditoría → Accesos y seguridad**	Revisar ráfagas de LOGIN_FAILED desde una misma IP
11b	Cambios fuera de lo común	Informe semanal de auditoría (correo del lunes o botón en Auditoría)	Revisar anulaciones y cambios fuera de horario
12	Bloqueos y límites del mes	Consultas del capítulo Seguridad de la aplicación	Revisar ACCOUNT_LOCKED repetidos y RATE_LIMIT desde IP desconocidas

#	Qué comprobar	Cómo	Esperado
13	Dependencias sin vulnerabilidades	Manual de infraestructura, capítulo «Gestión de vulnerabilidades»	No known vulnerabilities found
14	La clave privada está en custodia	Revisar que no esté en la PC ni en el servidor	Solo en USB o gestor de contraseñas
15	Usuarios activos que ya no trabajan en la clínica	Pantalla **Usuarios**	Ninguno: desactivar los que correspondan

22. Respuesta a incidentes

Un incidente es cualquier hecho que comprometa o pueda comprometer la confidencialidad, integridad o disponibilidad de la información: un acceso indebido, una contraseña filtrada, un equipo robado, datos borrados o el sistema caído.

Fase	Acciones
1. Detección	Alertas por correo de bloqueo de cuenta; revisión de **Seguridad → Auditoría** (ACCOUNT_LOCKED, RATE_LIMIT, LOGIN_FAILED); avisos de los usuarios; errores en los logs (docker logs syscomcli_app)
2. Contención	Bloquear o desactivar la cuenta comprometida. Cerrar sus sesiones y revocar su MFA (**Auditoría → Sesiones y usuarios**). Cambiar su contraseña desde **Usuarios**. Si se sospecha del servidor, cambiar las credenciales de servicio y la SECRET_KEY (cierra todas las sesiones)
3. Evaluación	Determinar qué datos se vieron afectados, desde cuándo y desde qué IP, con auditoria_sistema y accesos_sistema
4. Recuperación	Si los datos se dañaron, restaurar el último backup íntegro (Manual de infraestructura, capítulo «Backups y restauración», restauración de emergencia). Verificar que se pueda iniciar sesión y que los datos estén
5. Comunicación	Informar a la dirección de la clínica. Si hubo datos de pacientes expuestos, informar a los afectados según la normativa vigente
6. Registro y mejora	Documentar el incidente (fecha, causa, impacto, acciones) y ajustar estas políticas si corresponde

22.1 Casos frecuentes

Situación	Qué hacer primero
Un usuario cree que alguien usó su cuenta	Revocar MFA y cerrar sesiones (Auditoría → Sesiones y usuarios), cambiar su contraseña, revisar en Auditoría las IP y horarios de sus LOGIN y, en "Cambios en datos", qué modificó con esa cuenta
Se filtró el .env	Cambiar las contraseñas de sysclin_app y postgres (Manual de infraestructura, capítulo «Base de datos»), la SECRET_KEY, y las claves de SMTP y UltraMsg en sus

Situación	Qué hacer primero
	proveedores
Se perdió o robaron la PC o el USB con la clave privada del backup	Generar un par de claves nuevo y hacer un backup manual (Manual de infraestructura, capítulo «Backups y restauración»). Los backups viejos quedan ilegibles para quien no tenga la contraseña de la clave
Se borraron o alteraron datos por error	No hacer más cambios; restaurar el backup previo al error en una base de prueba con `restore_test.sh` para confirmar que tiene los datos, y recién entonces decidir la restauración de emergencia
El sistema está caído	Manual de infraestructura, capítulo «Manejo de contenedores», apartado «Reactivar el sistema»

23. Riesgos aceptados y normativa

23.1 Riesgos aceptados

Riesgo	Por qué se acepta	Mitigación
En desarrollo, los puertos 5005, 5434 y 5680 están abiertos a la red local	Se trabaja con varios proyectos en paralelo	En el servidor se cierran; en desarrollo no hay datos reales de pacientes
Un tercero puede bloquear una cuenta ajena con intentos fallidos	Es el costo del bloqueo por cuenta	El bloqueo indefinido requiere un administrador; queda auditado con la IP de origen
Dentro del contenedor de la base, las conexiones locales no piden contraseña	Requiere acceso a Docker, que equivale a ser administrador del equipo	El acceso al servidor queda restringido al administrador
Los backups están en el mismo disco que la base	Infraestructura de un solo equipo	Están cifrados; se recomienda una copia semanal fuera del equipo
Sin Content-Security-Policy	Las plantillas usan scripts en línea y CDNs	Mejora futura

23.2 Pendiente de incorporar

- Auditoría de cambios en los datos con el valor anterior y el nuevo, y registros de auditoría que no se puedan modificar ni borrar.
- Vistas y procedimientos almacenados: qué hay, cómo se usan y cómo probarlos.

23.3 Normativa de referencia

ISO/IEC 27001 (gestión de la seguridad de la información) y las buenas prácticas de OWASP se usan como **referencia**, no como certificación. El tratamiento de datos de salud se rige por la legislación paraguaya de protección de datos personales vigente.

Anexo A. Preguntas frecuentes

Pregunta	Respuesta
¿Por qué mi contraseña tiene que cumplir tantas reglas?	Porque una contraseña con mayúsculas, minúsculas, números y símbolos es mucho más difícil de adivinar. Una frase corta con un número y un símbolo es fácil de recordar y difícil de descubrir
¿El administrador puede ver mi contraseña?	No. Se guarda cifrada y nadie puede verla
¿Tengo que cambiar la contraseña cada cierto tiempo?	Sí. Vence cada 90 días y el sistema se lo avisa al ingresar
¿Por qué me pide un código si ya escribí mi contraseña?	Porque se necesitan las dos cosas: lo que usted sabe (la contraseña) y lo que usted tiene (su correo). Así una contraseña robada, por sí sola, no alcanza
Cambié de correo, ¿qué hago?	Avise al administrador: puede revocar su verificación en dos pasos para que usted vincule el correo nuevo
¿Por qué tengo que ingresar de nuevo cada tanto?	Porque la sesión se cierra tras 20 minutos sin uso, para que nadie use su sesión abierta
Anulé algo por error, ¿se puede recuperar?	Avise al administrador. Como nada se borra, el registro anulado y su historial siguen en el sistema

Anexo B. Glosario

Palabra	Significado
Anular	Dejar sin efecto un documento (factura, orden, cobranza) indicando el motivo. El documento no se borra: queda en el historial como anulado
Auditoría	Registro automático de quién hizo cada cambio en el sistema y cuándo
Bloqueo	Impedimento para entrar después de varios intentos fallidos con la contraseña: 30 minutos, luego 1 hora y luego hasta que un administrador lo levante
Cifrado	Transformar la información para que solo pueda leerla quien tiene la clave
Copia de respaldo	Copia de toda la información, guardada aparte para recuperarla si algo falla
Dispositivo confiable	Equipo en el que ya se verificó el código: el sistema lo recuerda 60 días y no vuelve a pedirlo ahí
Rol	Conjunto de permisos según la función de la persona: Recepción, Clínico, Ventas, Administrador o Superadministrador
Sesión	El tiempo que pasa desde que usted ingresa al sistema hasta que sale
Verificación en dos pasos	Ingreso con la contraseña más un código enviado al correo

Anexo C. Contactos

Complete y tenga a mano:

Rol	Nombre	Teléfono	Correo
Administrador del sistema			
Superadministrador			
Soporte técnico			